Exp 12: Implementing Security Features and Governance / Administration Practices in Zoho Creator

Name: Suriya S | Roll No: 241401112 | Dept. of Computer Science and Engineering, Rajalakshmi Engineering College

1. Aim

To implement security and governance practices for the Gym Membership Enrollment and Front Desk Management application in Zoho Creator by reviewing the platform's security controls, restricting what each user role can see and do, tracking user activity through the audit trail, and testing the restrictions with a sample user.

2. Procedure

2.1 Security and Governance Requirements

A gym application holds personal details, health notes, medical certificates and payment amounts, so access has to be controlled and activity has to be traceable. Five requirements were handled, as listed in Table 1.

Requirement	Component	Details
Protect sign-in	Security policies	Multi-factor authentication, password rules, IP restriction and session timeout, where the account plan allows
Limit access to data	Roles, profiles and permissions	Front desk, trainer and admin access to forms, reports and fields (built in Exp 8)
Protect public access	Form and report sharing	Only the enrolment form is public; reports stay private
Trace user activity	Audit trail	Record of who created, edited or deleted data
Keep a governance record	Administration checklist	Written practices for access reviews, backups and releases

Table 1: Security and governance requirements and the components used

2.2 Reviewing Security Controls

The Governance section under Manage in the Creator dashboard was opened to see which controls the account offers. Zoho lists security policies as a paid-plan feature, so some options may be locked on a trial account. Whatever was available was recorded, and any locked option was noted as a limitation. Table 2 lists the controls reviewed.

Control	What it does	Used in this application
Multi-factor authentication	Adds a second check after the password	Reviewed; enabled where the plan allows
Password policy	Forces strong passwords	Reviewed; enabled where the plan allows
IP restriction	Allows sign-in only from approved IP addresses	Reviewed; suited to the gym front-desk network
Session timeout	Signs out idle users	Reviewed; useful on shared front-desk computers
Audit trail	Keeps a tamper-proof history of user activity	Reviewed and used in 2.4
Data encryption and SSL	Protects stored data and data in transit	Platform default; no setting to change

Table 2: Security controls reviewed in the Governance section

241401112

[Insert your own screenshot here: Governance section showing the security options]

Figure 1: Governance section and security policies in the Creator dashboard

2.3 Restricting Access by Role

The roles and permissions built in Experiment 8 were reviewed against the sensitive fields of Membership_Enrollment_Form. The principle followed was least privilege: each role gets only the access its work needs. Table 3 shows the access plan.

Role	Forms and reports	Sensitive fields (medical certificate, health notes, fee paid)
Admin	Full access	Visible and editable
Front desk	Create and view enrolments; edit limited fields	Fee visible; health notes limited
Trainer	View assigned members only	Health notes and certificate visible; fee hidden

Table 3: Role-based access plan

[Insert your own screenshot here: a role's permission settings]

Figure 2: Permission settings for a role

A test user was then added with the Trainer role and signed in to confirm that the restricted fields and reports were hidden.

[Insert your own screenshot here: the application as seen by the test user]

Figure 3: Application as seen by the Trainer test user

2.4 Tracking Activity with the Audit Trail

The audit trail was opened to check that user activity is recorded. A sample enrolment was created, edited and then deleted, and the entries for these actions were located in the audit trail. Zoho recommends exporting audit data regularly, because old entries are not kept forever.

[Insert your own screenshot here: audit trail entries for the sample record]

Figure 4: Audit trail entries for the create, edit and delete actions

2.5 Checking Public Access and Sharing

Only the enrolment form needs to be open to prospective members. The sharing settings of the application were checked so that the form can be reached through its public link while reports, the Trainers_Master form and the family-member subform stay private to signed-in users.

[Insert your own screenshot here: sharing settings with only the enrolment form public]

24140112

Figure 5: Sharing settings of the application

2.6 Governance Practices

Technical controls need written habits to stay effective. The practices in Table 4 were adopted for the application.

Practice	How it is applied	Frequency
Access review	Check the user list and roles, and remove users who have left	Every month
Audit trail review and export	Look for unusual deletions or edits and save a copy of the log	Every quarter
Least privilege	Give new users the lowest role that lets them work	At each new user
Controlled releases	Test changes in development before deploying to production (Exp 11)	At each release
Backup check	Confirm that application backups exist before large changes	Before each release
Data minimisation	Collect only the member details the gym needs	At form design

Table 4: Governance practices for the application

3. Output

The figures above show the security options reviewed, the role permissions, the test user's restricted view, the audit trail entries and the sharing settings of the application.

Observations from the output

- Security in Creator works in layers: sign-in controls, role permissions, sharing settings and activity records each cover a different risk.
- Some governance options depend on the paid plan, so the available controls should be checked on the actual account.
- Giving the Trainer role no access to fee fields shows least privilege in practice and limits what a leaked login can expose.
- The audit trail answers who changed or deleted a record, which permissions alone cannot do.
- Keeping reports and the Trainers_Master form private while only the enrolment form is public keeps the exposed surface small.
- Written governance habits, such as monthly access reviews, are needed because settings alone do not stay correct as staff change.

4. Result

Security features and governance practices were implemented for the Gym Membership Enrollment and Front Desk Management application in Zoho Creator. Security controls were reviewed, role-based access was applied to sensitive fields and tested with a sample user, user activity was verified in the audit trail, public sharing was limited to the enrolment form, and a set of governance practices was recorded. This completes the security and governance requirements of this experiment.

2414011